

Let warnings interrupt the interaction and explain: designing and evaluating phishing email warnings

Paolo Buono

University of Bari, Computer Science Department
Italy
paolo.buono@uniba.it

Francesco Greco

University of Bari, Computer Science Department
Italy
francesco.greco@uniba.it

Giuseppe Desolda

University of Bari, Computer Science Department
Italy
giuseppe.desolda@uniba.it

Antonio Piccinno

University of Bari, Computer Science Department
Italy
antonio.piccinno@uniba.it

ABSTRACT

Phishing represents one of the most spread and effective cyber-attacks of our times. Warning messages are commonly employed in email clients to notify users about the possible danger and let them decide on their own. However, the high success rate of phishing attacks shows that the existing warnings are not yet adequate. This study contributes by proposing two novel warning dialogs for email clients that prevent users from immediately accessing the content of phishing emails. Specifically, the first one alerts the users against the potential scam, and the second one also reports explanations about the possible causes of the scam. A comparative between-subjects experiment with 300 participants has been performed. Results show that the proposed warnings better defend users from phishing emails than the warnings at the state-of-the-art. In addition, explanations resulted useful in preventing users from discarding genuine emails where warnings are displayed incorrectly due to misclassification of the email.

CCS CONCEPTS

• **Security and privacy** → *Usability in security and privacy*.

KEYWORDS

Phishing, Warnings, Explanations

ACM Reference Format:

Paolo Buono, Giuseppe Desolda, Francesco Greco, and Antonio Piccinno. 2023. Let warnings interrupt the interaction and explain: designing and evaluating phishing email warnings. In *Extended Abstracts of the 2023 CHI Conference on Human Factors in Computing Systems (CHI EA '23)*, April 23–28, 2023, Hamburg, Germany. ACM, New York, NY, USA, 6 pages. <https://doi.org/10.1145/3544549.3585802>

1 INTRODUCTION

Phishing is one of the biggest cyber threats of our time, being the top infection vector for gaining initial access to the victims' network

[16]. The forced transition to smart working due to the COVID-19 pandemic has allowed criminals to more easily take advantage of people who are not familiar with computer technologies, including the use of emails. Phishing attacks, indeed, exploit vulnerabilities of the user, who is often considered the “weakest link” in cybersecurity and is responsible for about 95% of all security incidents [15].

Current security solutions for email clients cannot automate phishing detection, i.e., they cannot automatically guard the user by deleting suspicious emails. Since even state-of-the-art AI solutions to detect phishing emails are very precise but not perfect [2, 18], complete automation would inevitably lead to genuine emails being deleted, jeopardizing the user's productivity. Therefore, in the existing phishing detection solutions, suspicious emails can be opened by users and then a warning dialog (e.g., a pop-up or a banner) alerts them about the potential danger, letting them decide about its legitimacy by themselves. However, the high success rate of phishing emails demonstrates that the existing warning dialogs for email clients are still not adequately protecting users [16]. One of the reasons is that the email content is often carefully created by the attackers to deceive the users (e.g., by mimicking genuine emails, by exploiting persuasive strategies) leading them to trust the phishing email more than the warning dialog [8]. Moreover, often users do not have adequate skills in IT and cybersecurity to understand the risks reported in the warning dialogs. Also, attackers exploit human factors such as fear and stress as well as anomalous working situations (i.e., working from home), which lead users to not consider these warning dialogs [11, 20].

To overcome the limitations of the existing warning dialogs in email clients and better defend users from phishing emails, this study presents a new active warning dialog that forces users to notice the warnings by interrupting them from opening the email. This is assuming that the content of the email can mislead the user into trusting the phishing email more than the warning message, thus it becomes important to alert them before reading the email content. Active warnings have been already successfully used for browsers and are more effective than passive warnings [10]. However, the presence of an active warning in a browser does not compensate for the weakness of warning dialogs in e-mail clients: if the user clicks on a malicious link in an email, when the browser is open the active warning is shown but it becomes less effective due to psychological effects such as anchor bias [1]. Thus, more

Permission to make digital or hard copies of part or all of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for third-party components of this work must be honored. For all other uses, contact the owner/author(s).

CHI EA '23, April 23–28, 2023, Hamburg, Germany

© 2023 Copyright held by the owner/author(s).

ACM ISBN 978-1-4503-9422-2/23/04.

<https://doi.org/10.1145/3544549.3585802>

effective warning dialogs must be shown for email clients. In addition, since the explanation is an important requirement to help users detect phishing emails [21, 26, 31], we also created a second active warning dialog that also includes messages explaining why the email is phishing.

A comparative experiment with 300 participants has been carried out to evaluate the warning dialogs proposed in this study, and compare them with the state-of-the-art [22]. The results showed that the active behavior of warning dialogs is, in general, a good strategy to improve their effectiveness. However, active behavior alone might be not sufficient since it can lead users to avoid opening legitimate emails when a warning dialog is wrongly shown. Our study demonstrated that the combination of the active behavior with explanation mechanisms improves both the effectiveness of active warning dialogs in case of real phishing emails and also better supports users in detecting false positives.

2 RELATED WORK

Early research on warning dialogs dates back to the '90s and has grown considerably over the past decades. A popular model for universal warnings communication is the Communication-Human Information Processing (C-HIP) model by Wogalter [27]. It describes how a message (e.g., the warning) is originated by a source and transmitted to a receiver (e.g., the user) through a channel (e.g., the computer screen). This model tells us that a warning message, in order to be heeded, has to be first noticed, then read, and then understood.

To alert users about phishing attacks, earlier solutions consisted of warnings that alert users about a potential danger without interrupting their main task (passive behavior). Their effectiveness was proven to be very low, as users often do not even notice that a warning has been shown to them [30]. In more recent years, active warnings have been proposed as a solution to the problem of passive warnings, as they block user activities and force interaction with them. With active warnings, it is possible to protect the user even if they do not read or understand the warning message by failing safely and preventing any damage by default [10].

Active warnings are the most adopted type of warning and we can find them in the most popular web browsers (e.g., Chrome, Firefox, Safari, etc.) to prevent users from accessing phishing websites [6]. Preventing users from accessing a phishing website can help them to avoid being cheated, as phishers use different techniques to lure the user into providing their sensitive information and can manage to deceive even more expert users [8].

While browsers adopt active warning dialogs to contrast phishing attacks, email clients (e.g., Gmail, Mozilla Thunderbird, etc.) still adopt *passive warnings* that notify users that an email might be suspect, for example, by showing a banner on the top of the email [6]. However, these warnings are likely to be ignored or not even noticed by users [30]. In the case of phishing emails in which the link is the hazard, a banner warning appears too far from the phishing link, not following common guidelines of being close to the hazard it guards against [28]. A study by Petelka et al. [22], investigated how the placement of the warning and the forced attention affected phishing susceptibility. They compared three solutions: 1) banner warnings, 2) warnings that appear directly in the email

client before or after clicking a phishing link in an email, and 3) warnings that appear in the web browser when visiting a phishing website. It emerged that the warning effectiveness was maximized when placing the warning message nearby the phishing link in the email client and forcing the users' attention by disabling it. This result not only confirms prior warning design theory about the effectiveness of placing a warning close in space and time to the hazard [28] but also suggests that browser warnings, which appear after a user has already decided to visit a phishing link, are less effective due to psychological effects like anchoring bias [1].

Another problem with warning dialogs in general is that they do not explain which specific elements are suspicious in the email (in the case of email clients) or website (in the case of browsers). This lack of information places the burden of locating them (e.g., a phishing link in the email) on the user, who may not have the knowledge and/or experience to acknowledge the danger. Warnings should indeed address the so-called human factors that negatively impact the phishing detection capabilities of the user, e.g., their lack of knowledge [7]. If human factors are not considered, they can lead to reckless behavior even in presence of warning dialogs explicitly telling them to not trust phishing content. Different human factors contribute to wrong user behavior; examples are the user's lack of knowledge (when they do not have the knowledge and/or experience to make the right choice), lack of awareness (when they do not pay enough attention to what they do) [7], and visual deception (when they are fooled into thinking that a counterfeit content that is shown to them is legitimate). Therefore, preventing the user from accessing phishing content, even in the case of emails, is thought to be beneficial for the same reasons since (spear-)phishing emails can deceive the user.

The study of Zheng and Becker [32] investigates how hiding the phishing content of an email by showing only the email header could improve the detection of phishing emails by the user. In an email, the header can indeed be manipulated less easily than the message body and generally contain more reliable indicators of the email's authenticity. Nonetheless, presenting users with only the email headers not only did not improve the performance compared to showing the whole email but even worsened it.

To the best of our knowledge, blocking the user before reaching dangerous content is an aspect that has not been explored in the case of phishing emails. Therefore, this work aims at investigating whether preventing the user from accessing the phishing email can lead to better warning effectiveness compared to the state-of-the-art. In addition, since explanation helps users detect phishing emails [21, 26, 31], we also proposed an active warning dialog that also explains why the email content might be a fraud.

3 ACTIVE WARNING DIALOGS WITH AND WITHOUT EXPLANATIONS

The analysis of the literature highlighted that the most effective warnings for browsers implement an active behavior, i.e., they block the users' interaction flow and force their attention to the alert, facilitating attention switch and attention maintenance (e.g., see [6, 10, 27, 30]). This strategy has proven to be better than passive solutions like banners and pop-ups (see, for example, [24, 30]). However, to the best of our knowledge, active warning dialogs have

been never explored for email clients, where instead only passive warning dialogs are used, as detailed in Section 2.

Since the user interaction flow in a phishing attack starts from an email, we believe that it is fundamental to adequately protect the users from the beginning, i.e., from email clients. Indeed, if users click on a malicious link in an email, the active warning shown in the browser becomes less effective due to psychological effects such as anchoring bias [1]. This pushes us in improving the protection from the early phases of a phishing attack, i.e., from the email client. This study contributes to the state-of-the-art by proposing two novel active warning dialogs for email clients.

The former warning dialog consists of a window shown when the user clicks, from the list of emails, on an email classified as suspicious (Figure 1a). Specifically, the warning blocks the user’s interaction flow in the email client by presenting them with a short message that alerts them about a possible risk in the email. The user cannot proceed to the suspicious email unless they click on the “Show Details” text, which expands the window with a section containing the “Click here” hyperlink that refers to the suspicious link of the email; therefore, the users are driven to read the dialog if they are willing to proceed, as the default option “fails safely” [10] and simply closes the dialog, bringing them back to the email client inbox.

The second warning dialog extends the previous one and also explains **why** the email might be dangerous. For example, in Figure 1b the warning alerts the user explaining that the email is a scam because the top-level domain in a URL in the email appears as a subdomain. Explanations about the threat can both motivate the user to heed the warning and help them take the right action [5, 21, 26]. Explanations are needed also to improve trust in the automated decision (i.e., the classification of an email as phishing) [17, 25], ultimately improving the effectiveness of warning dialogs [5]. Generating significant and effective explanations is not a trivial task: explanations have to report and simplify the technical motivations that led the phishing detection system to make its decision [25]. In this context, a possible approach would be employing explainable Artificial Intelligence (XAI) models: besides classifying the emails as phishing or genuine, they can compute the importance that the different features of an email had in its classification as malicious; the most important feature can be chosen as the rationale to explain to the user, who will see an explanation message in a human-readable form [14]. We already addressed this problem in [13], where different XAI models for phishing detection were built. First, from an analysis of the literature we identified all the features used to train phishing detection algorithms. The resulting set contained 140 features. It was reduced by filtering in only those features related to concepts easily explainable to the users. The final dataset contained 18 features and was used to train and compare different XAI models. For completeness of information, the best models are Explainable Boosting Machine (EBM) and Random Forest (RF), which achieve respectively 98.0% and 97.7% F1-score values. In addition, for each of the 18 features, we also designed 2 different explanation messages to be shown in the warning dialog according to the feature chosen by the XAI model. The resulting set of features and explanation messages are reported in the Appendix.

It is worth mentioning that the design of the warning dialogs proposed in this study took into account the Communication-Human

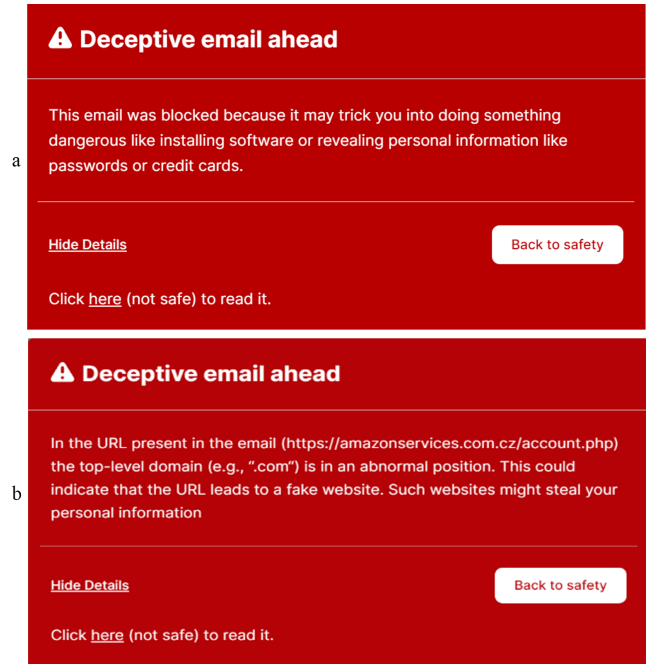


Figure 1: Active warning dialogs for email clients without (a) and with explanations (b).

Information Processing (C-HIP) model, which explains the important processes involved in the basic structuring of warning dialogs [27]. We also considered a set of guidelines that drive the generation of warning dialogs in security [3]. For example, they have a red background to convey danger [29], an “alert” symbol on the left to convey urgency [3], and two buttons on the bottom, with the right one being the safest and default choice for careless users [10]. The warning dialogs also describe the risk comprehensively but concisely [3]; in the case of warnings with explanations, the message follows a consistent layout by 1) explaining why the email might be dangerous, 2) explaining the hazard, and 3) explaining the consequences of a successful attack [4]. A video showing the warning dialogs proposed in this study is attached to this article.

4 METHOD

This section reports a comparative experiment carried out to evaluate whether the warning dialogs for email clients proposed in this study divert users from visiting phishing sites better than the solutions at the state-of-the-art. A critical point in blocking users before they see a suspicious email’s content is how they deal with false positives, i.e., legitimate emails that are erroneously classified as phishing. This aspect is often neglected when evaluating warning dialogs [22], thus we decided to investigate it in this study.

4.1 Research questions, study design, and participants

This study aims to answer the research question “Does preventing the user from accessing the email content improve their susceptibility to phishing attacks?”. A between-subject design was adopted. The

warning dialog is the independent variable. The between-subject levels are the two warnings proposed in this study (called *active* and *explanation* for short in the following) and a *baseline*. The *baseline* consists of a pop-up shown when users hover over a phishing link, which is deactivated to prevent users from directly accessing the suspect website; if the users want to proceed to the phishing website, they are forced to click the URL displayed in the warning. It has been selected as the *baseline* because it recently emerged as the best warning in defending users from phishing emails [22]. In

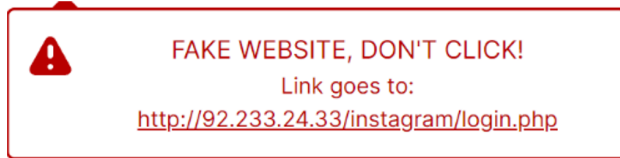


Figure 2: Baseline - passive warning based on the work of Petelka et al. [22]

order to perform the study remotely, an online email client platform inspired by the one used in [22] has been specifically developed to be administered through the *Prolific* (<https://www.prolific.co>) online platform. For this study, we initially gathered a total of 300 participants. After removing 3 careless participants [19], we recruited 3 further participants, obtaining a sample of 300 total participants (148 female, 149 male, and 3 other) with an average age of 35.99 (std 12.63). They spend, on average, 6.07 hours per day using the PC with a PC usage competence of 6.3/10. Participants were recruited worldwide with the only criteria of being native or fluent English speakers and that the sample is as balanced as possible between males and females. Participants have been assigned to have a balanced sample of 100 users in each condition. The study lasted around 15 minutes for each participant. We rewarded participants with 2.25£ each, according to the *Prolific*'s average participation fee of 9£/hour.

4.2 Measurements and Instruments

We logged all the user activity on the pages, including hovers and clicks over phishing links, URLs visited, and heeded or ignored warnings. This allowed us to measure the click-through rate (CTR), which is one of the most adopted metrics to assess the effectiveness of warning dialogs [12, 22]. CTR is obtained by dividing the number of users who clicked on a suspect link on the warning dialog by the number of people who did not click on that link.

The study has been carried out remotely on a platform specifically developed for this study. The developed platform guides the users in accomplishing the test and shows an email client that contains 14 emails. A total of 2 emails were designed to be phishing emails (the participants were never really endangered). The other 12 emails were legitimate emails based on real emails from different companies (e.g., Amazon, YouTube, etc.). One of these legitimate emails (specifically, from Facebook) was designed to be wrongly presented as a phishing email despite its legitimacy, i.e., the warning was shown despite it being safe; this simulates the case in which the system wrongly classifies the email as a false positive. The complete list of all the emails and the source code of the email

client is reported at this link https://anonymous.4open.science/r/email_client_phishing_warnings-ED8F.

4.3 Procedure

Deception has been used to avoid introducing priming effects in participants on the real goal of the experiment [9, 23]: inspired by similar studies [10, 22], we informed participants that the objective was to evaluate a new email client. After accepting our task in Prolific, participants opened a link where the web platform was installed. The first page gave an overview of the study and how the participants' answers would be used. Any participants who did not consent were free to quit the survey. It is worth mentioning that our university requires approval by an ethics committee only in the case of medical and clinical studies. For other studies like ours, they require that test participants give consent in a written or digital form; thus, we informed participants about all the details of the study and asked them to agree before starting the study. All of them agreed. Then, each participant was randomly assigned to one of the three experimental conditions. Participants were asked to follow a scenario where a user, Andrea, is assessing a new email client that his company has recently adopted. In line with other similar studies (e.g., [22]), participants were asked to interact with the new email client by reading all the emails in the inbox and checking that the links in them, if any, are working.

After reading the scenario, the email client was shown and, above it, the goal was always visible. In the email client, a list of email previews was shown in the "Inbox" area, reporting the sender's name, the tile, and the subject. This list was randomly ordered for each participant. By clicking on a legitimate email participants could access the email content. In the case of phishing emails, the warning corresponding to the experimental condition was shown. Specifically, in the case of active and explanation conditions, the warning appeared immediately after clicking on an email from the list, preventing the user from immediately viewing the content; they could access it only by clicking the "Details" button and then the "Click here" label shown in the details section. In the case of the baseline, a pop-up with an alert message and the target link appeared when the user hovers over a suspicious link in a phishing email, preventing the immediate click of the phishing link (Figure 2). After the interaction with each email (either by clicking on a link or by clicking on the back button), the participants were prompted with two questions "Who was the sender of the email?" and "Were there links in the email?" to test their attention and detect careless participants, which is an important aspect in case of remote tests [19].

Once participants interacted with all the emails, we thanked them for their contribution and redirected them back to the *Prolific* platform to obtain their reward.

4.4 Data analysis and Results

The collected data were analyzed using IBM SPSS. The Chi-square test was used to calculate statistical differences in the three conditions according to the CTR. An alpha level of .05 was used for the statistical tests. A summary of the CTR is reported in Figure 3. Specifically, it depicts the CTRs of the experimented conditions considering three dimensions: CTR of all the phishing emails (**true**

positive and false positive), CTR of the true positives, and the CTR of the false positives. The first dimension (true positives and

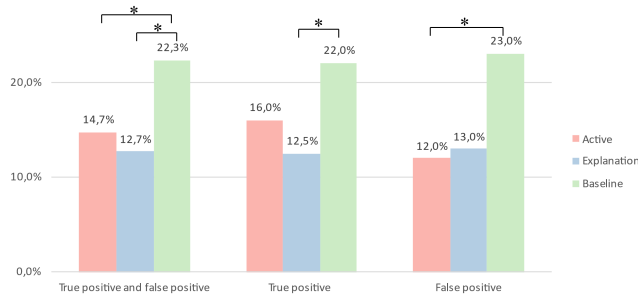


Figure 3: CTR of the three experimented warning dialogs. Asterisks are shown on the bars when there are statistically significant differences between the respective experimental conditions.

false positives) provides an overall view of the users' behavior when interacting with the warning dialogs, regardless of the genuineness of the email. The study results show that the CTRs of the warning dialogs proposed in this study are lower, thus better, than the *baseline*. The Chi-square test confirmed that the *active* condition is better than the *baseline* ($\chi(1) = 5.848$, $p = .016$) and that the *explanation* is better than the *baseline* ($\chi(1) = 9.709$, $p = .002$). No significant statistical differences emerged between active and explanation ($\chi(1) = .509$, $p = .476$).

The second dimension (**true positives**) provides an in-depth view of the users' behavior with real phishing emails. This is one of the most important aspects since it reflects the extent to which a warning protects a user. The result confirmed that the CTRs of the warning dialogs proposed in this study are lower, thus better, than the *baseline*. However, in this case, this difference is not statistically significant between the active condition and the *baseline* ($\chi(1) = 2.339$, $p = .126$), while the explanation condition is better than the *baseline* ($\chi(1) = 6.323$, $p = .012$). No differences emerged between active and explanation conditions ($\chi(1) = 1.003$, $p = .317$).

The third dimension (**false positive**) provides an interesting perspective on how the warning dialogs support the users to understand that the email is safe despite the visualization of the warning caused by a wrong classification of the email. In this case, the higher the CTR, the more effective the warning is in avoiding skipping safe and potentially useful emails. The study results show that the CTR of the *baseline* is higher, thus better, than the warning dialogs proposed in this study. However, this difference is statistically significant only in the case of the *active* warning ($\chi(1) = 4.190$, $p = .041$) while it is not significant in the case of the *explanation* condition ($\chi(1) = 3.338$, $p = .066$). No differences emerged between *active* and *explanation* conditions ($\chi(1) = .046$, $p = .831$).

5 DISCUSSION AND LESSONS LEARNED

The overall goal of this study was to understand if preventing the user from accessing the email content improves their susceptibility to phishing attacks. In the following, the answers to the research question are distilled in form of lessons learned.

Adopt active behavior to enhance warning dialogs. The results of the comparative experiment confirm that the active behavior in warning dialogs helps the users in avoiding being scammed by phishing emails better than the state-of-the-art solutions. In particular, the first dimension of the analysis demonstrates that both the solutions proposed in this study, which implement the active behavior, outperformed the best warning dialog at the state of the art. This confirms our assumption that the active behavior, i.e., blocking the users' interaction flow and forcing their attention to the warning dialog [10, 27, 30], might be a winning strategy also for email clients, as already happens for browsers [10].

Combine active behavior and explanation to further improve the warning's effectiveness. The second dimension of our analysis regards the CTR for phishing emails and reveals that the active behavior alone might be not sufficient to improve the effectiveness of the existing warning dialogs: despite the CTR of the *active* condition being lower than the *baseline* (16% vs 22%), this difference is not statistically significant. On the contrary, combining the active behavior with explanations resulted to be better than the *baseline*. In this case, the explanation enhances the trust in the warning, as already emerged in other studies [5, 21, 26].

Integrate explanations to support the detection of false positives. Useful details emerged from the third dimension of the analysis, which considers warning dialogs shown when users interact with genuine emails wrongly classified as a scam, as might happen in real situations. Let us suppose that a warning dialog has the best CTR, i.e., 0%; this means that users always avoid clicking the suspicious link in the warning dialog. The same result can be obtained by immediately blocking users when the AI model classifies the emails as suspicious. While this method may provide complete protection against phishing emails, it also risks preventing users from accessing genuine emails in the event of an incorrect classification by the AI model, which can negatively impact their productivity. Thus, it is crucial to investigate the CTR for phishing emails and false positive phishing emails. From the results of the third dimension of analysis, it emerged that the *active* warning dialog proposed in this study leads users to open fewer genuine emails than the *baseline*. This indicates that active behavior alone might worsen the detection of false positives. Luckily, the combination of the active behavior and explanation proposed in this study resulted in a winning strategy since the performances of the users are comparable to the *baseline*. This result indicates that the explanation not only improves the users' trust in the warning dialogs [21, 25, 26] but also provides useful insights that the users exploit to recognize false positives, reinforcing the importance of the explanation in warning dialogs.

6 CONCLUSION

This study investigated two novel warning dialogs for email clients that help users against phishing emails. The experiment revealed that they outperformed the warnings at the state-of-the-art because they prevent users from immediately accessing the email content. In addition, the explanations about the scam reported in the second warning further improve the detection of phishing emails and limit the discarding of false positives. These results can be considered very positive and might be a first step toward a wider investigation

of active behaviors and explanations in warning dialogs for email clients. However, our study has potential limitations. For example, to adopt the deception technique, participants were asked to read the email and check for valid links, which does not perfectly reflect how they use email clients every day. We also did not include emails with malicious attachments, which is another scenario that needs to be investigated. In the case of the explanation condition, only two explanation messages are used; thus, more interesting results could emerge from deeply analyzing all 18 messages. Lastly, this study compares the warnings only based on the CTR, but further quantitative (e.g., time to read the warning, CTR related to users' profiles), and qualitative (e.g., trust, understandability, habituation) data could be used in this comparison. We will also investigate all these aspects as future work in a longitudinal study.

ACKNOWLEDGMENTS

This work was partially supported by the project SERICS (PE00000014) under the NRRP MUR program funded by the EU - NGEU.

REFERENCES

- [1] Alessandro Acquisti, Idris Adjerid, Rebecca Balebako, Laura Brandimarte, Lorrie Faith Cranor, Saranga Komanduri, Pedro Giovanni Leon, Norman Sadeh, Florian Schaub, Manya Sleeper, Yang Wang, and Shomir Wilson. 2017. Nudges for Privacy and Security: Understanding and Assisting Users' Choices Online. *ACM Computing Survey* 50, 3 (2017), 41. <https://doi.org/10.1145/3054926>
- [2] Ammar Almomani, Brij B. Gupta, Samer Atawneh, Andrew Meulenberg, and Eman Almomani. 2013. A Survey of Phishing Email Filtering Techniques. *IEEE Communications Surveys & Tutorials* 15, 4 (2013), 2070–2090. <https://doi.org/10.1109/SURV.2013.030713.00020>
- [3] Lujo Bauer, Cristian Bravo-Lillo, Lorrie Faith Cranor, and Elli Fragkaki. 2013. Warning Design Guidelines (CMU-CyLab-13-002). Retrieved 16 Jan 2023 from https://kithub.cmu.edu/articles/journal_contribution/Warning_Design_Guidelines_CMU-CyLab-13-002_/6468131
- [4] Cristian Bravo-Lillo, Lorrie Faith Cranor, Julie Downs, and Saranga Komanduri. 2011. Bridging the Gap in Computer Security Warnings: A Mental Model Approach. *IEEE Security & Privacy* 9, 2 (2011), 18–26. <https://doi.org/10.1109/MSP.2010.198>
- [5] Cristian Bravo-Lillo, Lorrie Faith Cranor, Julie Downs, Saranga Komanduri, and Manya Sleeper. 2011. Improving Computer Security Dialogs. In *Human-Computer Interaction – INTERACT '11*, Pedro Campos, Nicholas Graham, Joaquim Jorge, Nuno Nunes, Philippe Palanque, and Marco Winckler (Eds.), Vol. LNCS. Springer Berlin Heidelberg, Berlin, Heidelberg, 18–35.
- [6] Giuseppe Desolda, Francesco Di Nocera, Lauren Ferro, Rosa Lanzilotti, Piero Maggi, and Andrea Marrella. 2019. Alerting Users About Phishing Attacks. In *HCI for Cybersecurity, Privacy and Trust (HCI-CPT '19)*, Abbas Moallem (Ed.). Springer International Publishing, Cham, 134–148.
- [7] Giuseppe Desolda, Lauren S. Ferro, Andrea Marrella, Tiziana Catarci, and Maria Francesca Costabile. 2021. Human Factors in Phishing Attacks: A Systematic Literature Review. *ACM Computing Survey* 54, 8 (2021), 35. <https://doi.org/10.1145/3469886>
- [8] Rachna Dhamija, J. D. Tygar, and Marti Hearst. 2006. Why Phishing Works. In *SIGCHI Conference on Human Factors in Computing Systems (CHI '06)*. ACM, New York, NY, USA, 581–590. <https://doi.org/10.1145/1124772.1124861>
- [9] Verena Distler, Matthias Fassl, Hana Habib, Katharina Krombholz, Gabriele Lenzini, Carine Lallemand, Lorrie Faith Cranor, and Vincent Koenig. 2021. A Systematic Literature Review of Empirical Methods and Risk Representation in Usable Privacy and Security Research. *ACM Trans. Comput.-Hum. Interact.* 28, 6, Article 43 (dec 2021), 50 pages. <https://doi.org/10.1145/3469845>
- [10] Serge Egelman, Lorrie Faith Cranor, and Jason Hong. 2008. You've Been Warned: An Empirical Study of the Effectiveness of Web Browser Phishing Warnings. In *SIGCHI Conference on Human Factors in Computing Systems (CHI '08)*. ACM, New York, NY, USA, 1065–1074. <https://doi.org/10.1145/1357054.1357219>
- [11] Jessica Ellis. 2020. COVID-19 Phishing Update: Campaigns Exploiting Hope for a Cure. Retrieved 16 Jan 2023 from <https://info.phishlabs.com/blog/covid-phishing-update-campaigns-addressing-a-cure>
- [12] Adrienne Porter Felt, Alex Ainslie, Robert W. Reeder, Sunny Consolvo, Somas Thyagaraja, Alan Bettis, Helen Harris, and Jeff Grimes. 2015. Improving SSL Warnings: Comprehension and Adherence. In *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems* (Seoul, Republic of Korea) (CHI '15). ACM, New York, NY, USA, 2893–2902. <https://doi.org/10.1145/2702123.2702442>
- [13] Francesco Greco. 2022. *An explainable AI model to help users avoid being victims of phishing attacks*. Master's thesis. University of Bari.
- [14] Riccardo Guidotti, Anna Monreale, Salvatore Ruggieri, Franco Turini, Fosca Giannotti, and Dino Pedreschi. 2018. A Survey of Methods for Explaining Black Box Models. *ACM Comput. Surv.* 51, 5, Article 93 (aug 2018), 42 pages. <https://doi.org/10.1145/3236009>
- [15] IBM. 2014. Cyber Security Intelligence Index. Retrieved 16 Jan 2023 from <https://i.crn.com/sites/default/files/ckfinderimages/userfiles/images/crn/custom/IBMSecurityServices2014.PDF>
- [16] IBM. 2022. X-Force Threat Intelligence Index. Retrieved 16 Jan 2023 from <https://www.ibm.com/downloads/cas/ADLMYLZ>
- [17] Kareem Khalifa. 2013. The Role of Explanation in Understanding. *The British Journal for the Philosophy of Science* 64 (2013), 161–187. <https://doi.org/10.2307/23356461>
- [18] Mahmoud Khonji, Youssef Iraqi, and Andrew Jones. 2013. Phishing Detection: A Literature Survey. *IEEE Communications Surveys & Tutorials* 15, 4 (2013), 2091–2121. <https://doi.org/10.1109/SURV.2013.032213.00009>
- [19] Tenga Matsuura, Ayako A. Hasegawa, Mitsuaki Akiyama, and Tatsuya Mori. 2021. Careless Participants Are Essential for Our Phishing Study: Understanding the Impact of Screening Methods. In *Proceedings of the 2021 European Symposium on Usable Security (Karlsruhe, Germany) (EuroUSEC '21)*. ACM, New York, NY, USA, 36–47. <https://doi.org/10.1145/3481357.3481515>
- [20] Elizabeth Montalbano. 2020. Top Email Protections Fail in Latest COVID-19 Phishing Campaign. Retrieved 16 Jan 2023 from <https://threatpost.com/top-email-protections-fail-covid-19-phishing/154329/>
- [21] Norbert Nthala and Rick Wash. 2021. How Non-Experts Try to Detect Phishing Scam Emails. *Workshop on Technology and Consumer Protection (ConPro '21)* (2021). <https://www.ieee-security.org/TC/SPW2021/ConPro/papers/nthala-conpro21.pdf>
- [22] Justin Petelka, Yixin Zou, and Florian Schaub. 2019. Put Your Warning Where Your Link Is: Improving and Evaluating Email Phishing Warnings. In *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems* (Glasgow, Scotland UK) (CHI '19). ACM, New York, NY, USA, 1–15. <https://doi.org/10.1145/3290605.3300748>
- [23] Andreas Sotirakopoulos, Kirstie Hawkey, and Konstantin Beznosov. 2011. On the Challenges in Usable Security Lab Studies: Lessons Learned from Replicating a Study on SSL Warnings. In *Proceedings of the 7th Symposium on Usable Privacy and Security (Pittsburgh, Pennsylvania) (SOUPS '11)*. ACM, New York, NY, USA, Article 3, 18 pages. <https://doi.org/10.1145/2078827.2078831>
- [24] Joshua Sunshine, Serge Egelman, Hazim Almuhamdi, Neha Atri, and Lorrie Faith Cranor. 2009. Crying Wolf: An Empirical Study of SSL Warning Effectiveness. In *Conference on USENIX Security Symposium*. USENIX Association, USA, 399–416.
- [25] Giulia Vilone and Luca Longo. 2021. Notions of explainability and evaluation approaches for explainable artificial intelligence. *Information Fusion* 76 (2021), 89–106. <https://doi.org/10.1016/j.inffus.2021.05.009>
- [26] Rick Wash. 2020. How Experts Detect Phishing Scam Emails. *Proc. of ACM on Human-Computer Interaction* 4, CSCW2, Article 160 (oct 2020), 28 pages. <https://doi.org/10.1145/3415231>
- [27] Michael S. Wogalter. 2018. Communication-human information processing (C-HIP) model. In *Forensic Human Factors and Ergonomics* (1st ed.), Michael S. Wogalter (Ed.). CRC Press, Boca Raton, 33–49. <https://doi.org/10.1201/9780429462269-3>
- [28] Michael S. Wogalter, Vincent C. Conzola, and Tonya L. Smith-Jackson. 2002. Research-based guidelines for warning design and evaluation. *Applied Ergonomics* 33, 3 (2002), 219–230. [https://doi.org/10.1016/S0003-6870\(02\)00009-1](https://doi.org/10.1016/S0003-6870(02)00009-1)
- [29] Michael S. Wogalter, Christopher B. Mayhorn, and Olga A. Zielinska. 2015. Use of color in warnings. In *Handbook of Color Psychology*, Andrew J. Elliot, Anna Franklin, and Mark D. Fairchild (Eds.). Cambridge University Press, Cambridge, 377–400. <https://doi.org/10.1017/CBO9781107337930.019>
- [30] Min Wu, Robert C. Miller, and Simson L. Garfinkel. 2006. Do Security Toolbars Actually Prevent Phishing Attacks?. In *SIGCHI Conference on Human Factors in Computing Systems (CHI '06)*. ACM, New York, NY, USA, 601–610. <https://doi.org/10.1145/1124772.1124863>
- [31] Weining Yang, Aiping Xiong, Jing Chen, Robert W. Proctor, and Ninghui Li. 2017. Use of Phishing Training to Improve Security Warning Compliance: Evidence from a Field Experiment. In *Proceedings of the Hot Topics in Science of Security: Symposium and Bootcamp (Hanover, MD, USA) (HotSoS)*. ACM, New York, NY, USA, 52–61. <https://doi.org/10.1145/3055305.3055310>
- [32] Sarah Zheng and Ingolf Becker. 2022. Presenting Suspicious Details in User-Facing E-mail Headers Does Not Improve Phishing Detection. In *Symposium on Usable Privacy and Security (SOUPS '22)*. USENIX Association, Boston, MA, Article 7, 15 pages. <https://www.usenix.org/conference/soups2022/presentation/zheng>

Received 18 January 2023; revised 25 February 2023; accepted 26 February 2023